

SIMATS ENGINEERING (SAVEETHA SCHOOL OF ENGINEERING)

Department of Computer Science and Engineering

ASSESSMENT TOOL 1 – Secure Infrastructure Architecture

Course Code:	CSA5803	Course Title:	DEVSECOPS ENGINEERING AND APPLICATION SECURITY
CO Assessed:	CO4 – Precision (BL1, BL2, BL3)	Assessment:	Assessment Tool 1
Weightage:	30% of CIA	Total Marks:	100
CO3 Statement:	Design Secure Infrastructure Architecture using DiagrammeR or Drawio.		
Student Name:	Harish T	Reg. No.:	192521373
Section / Batch:	B Tech IT 2025	Date:	18/08/26

Instructions to Students

- Design a Secure Infrastructure Architecture for the selected application/system using DiagrammeR or Draw.io.
- Include essential components such as Firewall, WAF, LoadBalancer, Web/ApplicationServer, Database, IAM, IDS/IPS, and Monitoring/Logging wherever applicable.
- Clearly represent network zones, dataflow, security controls, and trust boundaries in the architecture.
- Ensure the diagram is original, professionally formatted, clearly labelled, and submitted along with its editable source file.

Question Type	Focus Area	Questions	Marks
Secure Infrastructure Architecture	Conceptual Understanding	Q1	Q1 –100
GRAND TOTAL:		100 Marks	

Code of Conduct

I Harish T (192521373)(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the Student: Harish T

ASSESSMENT TOOL 1 – SECURE INFRASTRUCTURE ARCHITECTURE

CSA5803 – DevSecOps Engineering and Application Security

Q1. Design a Secure Infrastructure Architecture for an Airline Reservation System

Selected System: Airline Reservation System with Customer Portal, API Gateway, Booking Services, Payment Service, Database, Segmented Network Zones, and Monitoring.

1. Understanding of the Problem Context

The Airline Reservation System is a customer-facing application for flight search, customer authentication, booking, reservation management, and payment-related operations. Since the system handles customer information, reservation data, and payment requests, public-facing components must be separated from internal application and data services.

The architecture uses segmented network zones, controlled data flow, security controls, and clear trust boundaries. The assessment requires Firewall, WAF, Load Balancer, Web/Application Server, Database, IAM, IDS/IPS, and Monitoring/Logging wherever applicable, together with an original Draw.io or DiagrammeR diagram and editable source file.

2. Proposed Secure Architecture

The architecture is divided into five logical zones: Internet/Untrusted Zone, Perimeter/DMZ Zone, Application Zone, Data Zone, and Security/Management Zone.

Network Zone	Components	Security Purpose
Internet / Untrusted Zone	Customers and airline staff/admin users	External untrusted network; only approved HTTPS traffic reaches the perimeter.
Perimeter / DMZ Zone	Firewall, WAF, Load Balancer, API Gateway	Filters traffic, protects web/API endpoints and distributes legitimate requests.
Application Zone	Customer Portal, Booking Service, Payment Service	Runs business logic; direct Internet access is prohibited.
Data Zone	Airline Reservation Database	Stores protected reservation and customer data; no direct Internet access.
Security / Management Zone	IAM, IDS/IPS, Monitoring and Logging	Authentication, authorization, threat detection, alerting and centralized security visibility.

3. Components and Security Controls

Firewall: Filters inbound and outbound traffic and permits only required services.

WAF: Protects customer portal and API endpoints from common web-layer attacks and malicious requests.

Load Balancer: Distributes legitimate requests among available application instances and improves availability.

API Gateway: Provides a controlled API entry point, request routing, authentication/authorization controls, rate control and API monitoring.

Customer Portal: Provides flight search, login, booking and reservation functions; it does not connect directly to the database.

Booking Service: Processes flight selection, reservation creation, cancellation and booking rules.

Payment Service: Processes payment-related requests through a restricted internal service path.

Database: Stores customer, flight, reservation and transaction-related information in the protected Data Zone.

IAM: Manages authentication, authorization, roles and access privileges.

IDS/IPS: Detects suspicious network activity and supports prevention of malicious traffic.

Monitoring / Logging: Collects application, API, authentication, network and security events for monitoring and analysis.

4. Secure Data Flow

- A customer accesses the Customer Portal through HTTPS.
- The Firewall filters the incoming connection according to security policy.
- Approved web traffic is inspected by the WAF.
- The Load Balancer distributes the request to the appropriate application entry point.
- The API Gateway validates and controls API requests before routing them to internal services.
- Flight-search and reservation requests are forwarded to the Booking Service.
- When payment is required, the Booking Service communicates with the Payment Service through a restricted internal path.
- Authorized application services communicate with the Database through controlled internal connections.
- IAM provides authentication and authorization for users, administrators and protected service access.
- IDS/IPS monitors network activity while Monitoring/Logging collects application and security events.
- The booking or payment status is returned to the customer through the controlled application path.

5. Trust Boundaries

- Internet to Perimeter: separates untrusted customers from protected infrastructure; Firewall and WAF controls are applied.
- Perimeter to Application: separates externally reachable components from internal business services; API Gateway and controlled routing restrict access.
- Application to Data: prevents direct database access from Internet users; only authorized application services access the database.
- Production to Security/Management: restricts administrative and monitoring access to authorized personnel and security components.

6. Draw.io / DiagrammeR Architecture Layout

Reproduce the following structure as the original professional diagram in Draw.io or DiagrammeR:

[INTERNET / UNTRUSTED ZONE]

Customers / Airline Staff

|

HTTPS

v

[PERIMETER / DMZ ZONE]

Firewall -> WAF -> Load Balancer -> API Gateway

|

v

[APPLICATION ZONE]

Customer Portal -> Booking Service -> Payment Service

|
v

[DATA ZONE]

Airline Reservation Database

[SECURITY / MANAGEMENT ZONE]

IAM IDS/IPS Monitoring/Logging

Monitoring/Logging <--- Application / API / Database / Security Events

IDS/IPS <----- Network Traffic

IAM -----> Authentication / Authorization

7. Recommended Diagram Labels

- Use an outer boundary labelled Secure Airline Reservation Infrastructure.
- Create clearly separated containers for DMZ, Application, Data and Security/Management zones.
- Place customers outside the infrastructure trust boundary in the Internet/Untrusted Zone.
- Use directional arrows for HTTPS requests and internal service communication.
- Clearly label Firewall, WAF, IAM, IDS/IPS and Monitoring/Logging.
- Show that the Database is inside the Data Zone and has no direct Internet connection.
- Show API Gateway as the controlled entry point to internal services.
- Include a legend for network zones, trust boundaries, security controls and data-flow arrows.

8. Security and Availability Justification

- Network segmentation limits the impact of a compromise by separating Internet-facing, application, data and management resources.
- Firewall and WAF controls reduce unauthorized network and web-layer access.
- The API Gateway centralizes API access control and provides a controlled route to internal services.
- The Load Balancer improves availability by distributing requests across application instances.
- Database isolation protects reservation and customer information from direct external access.
- IAM enforces identity-based access and reduces unauthorized administrative or service access.
- IDS/IPS provides visibility into suspicious network activity.
- Centralized monitoring and logging support detection, investigation and response to security events.

9. Expected Result

A secure and logically segmented infrastructure architecture is designed for the Airline Reservation System. Customer access is controlled through the Firewall, WAF, Load Balancer and API Gateway; Booking and Payment Services are isolated inside the Application Zone; the reservation database is protected in the Data Zone; and IAM, IDS/IPS and Monitoring/Logging provide identity control, threat detection and continuous visibility.

Conclusion

The proposed architecture provides layered protection for an Airline Reservation System. Customers reach the system through controlled perimeter components, while the API Gateway regulates access to Booking and Payment Services. The Database is isolated in a protected Data Zone, and IAM, IDS/IPS and Monitoring/Logging provide identity control, threat detection and continuous visibility. The design therefore satisfies the assessment focus on network zones, data flow, security controls and trust boundaries.